Case Study 1: Security Assessment of a University Web Portal

A university plans to conduct an authorized security assessment of its student information portal. The portal allows students to log in, check attendance, download examination schedules, view grades, and update selected personal information. The university has provided the ethical hacking team with written permission to test the application and its associated servers. The testing team is instructed not to modify actual student records and to use designated test accounts wherever possible.

The first phase is **reconnaissance**. The team collects publicly available information about the university's technology environment. They identify the official domain, subdomains used for different services, publicly visible technology information, and contact information for the IT department. They also review publicly available documentation and information that might reveal the software platforms used by the portal. The team records every finding in a structured assessment document.

During **scanning**, the team examines the authorized portal and its test infrastructure. They identify accessible services, application technologies, server versions where legitimately exposed, and potential weaknesses in the configuration. They also examine how the web application responds to different requests. The objective is to understand the attack surface rather than immediately exploit every discovered weakness.

The team then moves to **gaining access**. Using a designated test account, they evaluate authentication and authorization controls. They discover that one test user can access a function that should be restricted to another role. The finding suggests a possible authorization weakness. Instead of accessing real student information, the testers demonstrate the issue using synthetic records supplied by the university.

The next phase is **maintaining access**. In an authorized assessment, this phase does not mean secretly installing persistent malware. Instead, the team determines whether a successful compromise could allow an attacker to retain unauthorized access. They review session management, token expiration, password-reset mechanisms, account recovery, and other persistence-related controls.

Finally, the team examines **covering tracks** from a defensive perspective. They determine whether important security events would remain visible in application logs, authentication logs, and monitoring systems. They verify whether suspicious activities generate alerts and whether logs contain sufficient information for an investigator to reconstruct an incident. The team prepares a report describing vulnerabilities, evidence, risk levels, and recommended controls.

Questions

1. What is the first phase of ethical hacking?
2. What information is collected during reconnaissance?
3. What is the purpose of scanning?
4. What is an example of an authorization weakness?
5. Why should real student records not be modified?
6. What does maintaining access evaluate?
7. What is session management?
8. Why are logs important?
9. What is the purpose of security monitoring?
10. What is the final output of an ethical hacking assessment?

Case Study 2: Security Assessment of an E-Commerce Application

An online shopping company decides to conduct an authorized security assessment of its e-commerce platform. Customers use the website to create accounts, search for products, add items to shopping carts, make payments, and track orders. Because the application processes sensitive customer and transaction information, management wants to identify security weaknesses before they are exploited by criminals.

The ethical hacking team begins with **reconnaissance**. They collect information about the company's public web presence and identify domains, subdomains, publicly available application documentation, and technologies visible from legitimate sources. They distinguish between information that is publicly available and information that requires authorization to access. The security team establishes a testing scope so that third-party payment systems and unrelated infrastructure are excluded.

During **scanning**, the testers examine the authorized application. They identify available services and application components and study how the application communicates with the backend. They observe requests generated when users search for products, log in, add products to carts, and view order information. The objective is to understand the application's attack surface.

During **gaining access**, the testers evaluate vulnerabilities using approved test accounts and test data. They discover that changing an identifier in a request may allow one test customer account to view another test customer's order information. The team stops after demonstrating the problem with synthetic accounts. This indicates a potential broken access-control vulnerability.

During **maintaining access**, the team investigates whether compromised sessions or accounts could remain usable for an extended period. They examine session expiration, logout behavior,

password changes, password-reset mechanisms, and account-recovery controls. They discover that an old session remains active after a password change, which could increase the impact of an account compromise.

During the **covering tracks** phase, the testers do not attempt to erase evidence. Instead, they evaluate whether the company's monitoring mechanisms would detect suspicious activities. They check whether repeated access to different customer records would be logged and whether unusual account activity would generate alerts. The security team recommends stronger access controls, session invalidation after password changes, centralized logging, and improved monitoring.

The final report categorizes the findings according to severity and business impact. The company prioritizes the access-control weakness because unauthorized disclosure of customer order information could affect confidentiality and regulatory compliance.

Questions

1. What type of application is assessed in this case?
2. What is reconnaissance used for?
3. What does scanning identify?
4. What vulnerability was identified in the case?
5. Why were synthetic accounts used?
6. What does session expiration control?
7. Why should old sessions be invalidated after a password change?
8. What is centralized logging?
9. What does monitoring help detect?
10. Why was the access-control issue prioritized?

Case Study 3: Authorized Assessment of a Hospital Management System

A hospital operates a computerized management system used by doctors, nurses, reception staff, laboratory personnel, and administrators. The system manages appointments, laboratory reports, prescriptions, billing information, and patient records. Because the system contains highly sensitive information, hospital management authorizes a controlled ethical hacking exercise using a dedicated testing environment containing fictional patient data.

The assessment begins with **reconnaissance**. The security team identifies the systems included in the testing scope, application domains, user roles, publicly visible technologies, and documentation related to the hospital's test environment. The team creates a diagram showing the relationship between the web application, application server, database server, and authentication service.

During **scanning**, the testers examine the test environment for accessible services, application components, configuration weaknesses, and outdated technologies. They also examine how different user roles interact with the application. The objective is to identify possible entry points and weaknesses while ensuring that production medical systems are not affected.

In the **gaining access** phase, the testers evaluate authentication and authorization using test accounts. They discover that a laboratory-user account can access a function intended only for administrative users. The testers document the issue without accessing real medical records. They also evaluate password policies and account-lockout behavior using approved testing procedures.

The next phase is **maintaining access**. The security team considers what could happen if an attacker obtained a legitimate test account. They evaluate session expiration, account recovery, password changes, authentication tokens, and privileged-account management. They identify a weakness in which an old authenticated session can remain active after an administrator changes the account password.

The final phase, **covering tracks**, is approached from the perspective of detection and incident response. The testers verify whether privilege-related activities are recorded and whether security administrators can identify unusual behavior. They examine whether logs include timestamps, usernames, source information, and the affected resources. The team emphasizes that an ethical tester should not delete or manipulate evidence in a real environment.

The hospital receives recommendations including stronger role-based access control, improved session management, centralized logging, multi-factor authentication for privileged accounts, and continuous security monitoring. The case demonstrates why ethical hacking is not simply about obtaining access; it is a structured process for identifying and reducing security risks.

Questions

1. Why was a dedicated test environment used?
2. What is reconnaissance in this case?
3. What does scanning examine?
4. Which security weakness was discovered?
5. What does role-based access control do?
6. What is authentication?
7. What is authorization?
8. Why is multi-factor authentication useful?
9. What information should security logs contain?
10. Should ethical hackers delete security evidence?

Case Study 4: Security Testing of a Smart-Campus Network

A university introduces a smart-campus infrastructure containing smart classrooms, networked projectors, access-control systems, environmental sensors, IP cameras, and centralized management servers. Concerned about cybersecurity risks, the university authorizes a security team to assess the infrastructure in a controlled laboratory network. The assessment excludes production devices and personal devices belonging to students and staff.

The testers begin with **reconnaissance**. They identify the systems included in the test scope and document the network architecture. They collect information about device types, network segments, management interfaces, and communication technologies. They also identify which systems are considered critical.

During **scanning**, the testers identify active systems and services in the laboratory network. They examine device configurations and determine whether unnecessary services are enabled. They also evaluate whether network segmentation separates administrative systems from less trusted devices. The assessment identifies several devices that expose management services unnecessarily.

During **gaining access**, the testers use authorized test credentials and controlled vulnerability demonstrations. One smart classroom controller is found to use weak authentication controls. The testers demonstrate that unauthorized access could potentially allow changes to classroom equipment settings. They do not modify production equipment.

During **maintaining access**, the team examines whether an attacker who obtains access to a smart device could continue using that access. They review credential management, session expiration, firmware-update mechanisms, device certificates, and administrative account controls. They identify inadequate credential rotation as a potential risk.

The **covering tracks** phase focuses on whether the university's monitoring infrastructure can identify suspicious activity. The testers examine network logs and security alerts to determine whether unexpected administrative access is visible. They simulate approved suspicious behavior and check whether the security monitoring system produces appropriate alerts.

The assessment concludes that the university should improve network segmentation, disable unnecessary management services, enforce stronger authentication, regularly update device firmware, rotate credentials, and improve centralized monitoring. The report also recommends maintaining an inventory of connected devices because unknown or unmanaged devices can create significant security risks.

This case demonstrates that ethical hacking can be applied not only to traditional websites but also to interconnected cyber-physical and IoT environments.

Questions

1. What type of infrastructure is assessed?
2. Why was production equipment excluded?
3. What is network segmentation?
4. What problem was discovered during scanning?
5. What weakness was demonstrated during gaining access?
6. What does credential rotation mean?
7. Why are firmware updates important?
8. What is security monitoring used for?
9. Why is device inventory important?
10. What is one recommended security measure?

Case Study 5: Security Assessment of a Financial Services Portal

A financial services organization operates an online portal through which customers can view account information, submit service requests, and communicate with customer-support representatives. Because the system processes financially sensitive information, the organization hires an ethical hacking team to conduct a controlled security assessment.

The assessment begins with **reconnaissance**. The testers identify the domains, authorized application components, technology information, user roles, and publicly available documentation associated with the testing scope. They also identify information that could help an attacker understand the organization's external attack surface. All findings are documented before active testing begins.

During **scanning**, the team examines the authorized systems for accessible services, application components, configuration weaknesses, and security controls. They analyze the application's authentication mechanisms and study the requests generated by normal user activities. They also review security headers and other defensive controls.

During **gaining access**, the testers use approved accounts to evaluate authentication and authorization. They identify a weakness in an account-recovery workflow that could potentially allow an attacker to bypass an intended verification step. The team demonstrates the weakness using a test account and immediately reports it because financial systems require strict controls around account recovery.

During **maintaining access**, the testers investigate whether an attacker who obtains access to an account could retain access after security events such as password changes or account recovery. They examine session invalidation, token lifetime, account lockout, and administrative controls. They identify that some sessions remain active longer than expected.

The **covering tracks** phase is conducted primarily as a detection assessment. Rather than removing logs, the testers determine whether suspicious account activity can be reconstructed from available evidence. They check whether authentication events, account changes, failed verification attempts, and administrative actions are recorded and monitored.

The organization responds by strengthening account-recovery verification, improving session management, implementing stronger authentication, improving security logging, and establishing alerts for unusual account activity. The security team also recommends regular penetration testing and continuous vulnerability management.

The case illustrates the importance of performing every ethical hacking phase systematically. Reconnaissance helps understand the target, scanning identifies possible weaknesses, gaining access validates security controls, maintaining access evaluates persistence risks, and covering tracks helps determine whether the organization can detect and investigate an attack.

Questions — One-Line Answers

1. What type of system was tested?
2. What is the objective of reconnaissance?
3. What happens during scanning?
4. What weakness was discovered?
5. Why was a test account used?
6. What does session invalidation accomplish?
7. What is account lockout?
8. What is the purpose of security logging?
9. What is continuous vulnerability management?
10. What is the overall goal of ethical hacking?

1. Which are phases commonly associated with ethical hacking?

A. Reconnaissance
B. Scanning
C. Gaining Access
D. Maintaining Access
E. Covering Tracks

2. What is the primary purpose of reconnaissance?

A. Collect information about the target
B. Understand the attack surface
C. Identify potentially relevant technologies
D. Immediately destroy target systems

3. Which activities can be part of reconnaissance?

A. Identifying domains
B. Collecting publicly available information
C. Identifying organizational technology information
D. Deleting system logs

4. Which information can help an ethical hacker understand a target?

A. Domain names
B. Subdomains
C. Technology information
D. Authorized organizational documentation

5. What is passive reconnaissance generally characterized by?

A. Using publicly available information
B. Avoiding direct intrusive interaction with the target
C. Collecting information before active testing
D. Immediately modifying target systems

6. Why is reconnaissance important?

A. It helps define the attack surface
B. It supports later testing phases
C. It can reveal publicly exposed information
D. It automatically fixes vulnerabilities

7. What is scanning intended to identify?

A. Active systems
B. Accessible services
C. Potential weaknesses
D. Security-relevant configurations

8. Which can be examined during vulnerability scanning?

A. Open services
B. Application components
C. Configuration weaknesses
D. Potentially outdated software

9. Which tools are commonly associated with authorized network scanning?

A. Nmap
B. Vulnerability scanners
C. Network monitoring tools
D. Word processors

10. What is an important rule during scanning?

A. Stay within the authorized scope
B. Avoid unnecessary disruption
C. Document findings
D. Scan unrelated systems without permission

11. Which are examples of information that scanning may reveal?

A. Open ports
B. Available services
C. Service versions
D. Network hosts

12. What is the relationship between reconnaissance and scanning?

A. Reconnaissance gathers initial information
B. Scanning provides more technical information about accessible systems
C. Both contribute to understanding the attack surface
D. They are always exactly the same activity

13. What is the objective of gaining access in an ethical assessment?

A. Validate identified weaknesses
B. Demonstrate security impact in a controlled manner
C. Determine whether security controls can be bypassed
D. Cause permanent damage

14. Which security controls may be evaluated during gaining access?

A. Authentication
B. Authorization
C. Input validation
D. Access-control mechanisms

15. What is authentication?

A. Verifying identity
B. Confirming that a user is who they claim to be

C. A security control
D. Determining which files a user may access

16. What is authorization?

A. Determining permitted actions
B. Controlling access to resources
C. Enforcing user privileges
D. Proving a person's identity

17. Which can indicate an authorization problem?

A. A normal user accessing administrator functionality
B. One customer accessing another customer's information
C. A restricted function being accessible to an unauthorized role
D. A properly enforced access-control policy

18. Why should ethical hackers use test accounts?

A. To reduce risk
B. To avoid affecting real users
C. To provide controlled evidence
D. To hide unauthorized activity

19. What does maintaining access refer to?

A. Evaluating persistence after initial compromise
B. Examining session management
C. Assessing account recovery mechanisms
D. Permanently damaging the target

20. Which controls are relevant to maintaining-access assessments?

A. Session expiration
B. Password changes
C. Token invalidation
D. Account recovery

21. Why is session invalidation important?

A. It can terminate compromised sessions
B. It reduces the duration of unauthorized access
C. It strengthens session management
D. It guarantees that every vulnerability is removed

22. Which situations may increase persistence risk?

A. Long-lived sessions
B. Weak account-recovery mechanisms
C. Failure to invalidate old authentication tokens
D. Strong session expiration

23. Which mechanisms can help prevent unauthorized persistence?

A. Session expiration
B. Token invalidation
C. Strong authentication
D. Proper account management

24. Why is maintaining access tested ethically?

A. To understand the potential impact of compromise
B. To evaluate persistence-related controls
C. To recommend defensive improvements
D. To secretly maintain access indefinitely

25. What is the ethical approach to persistence testing?

A. Use controlled test environments
B. Obtain authorization
C. Minimize impact
D. Maintain unauthorized access after testing

26. What does covering tracks traditionally refer to?

A. Attempts by attackers to hide their activities
B. Removal or manipulation of evidence
C. Avoiding detection
D. Improving security logging

27. In ethical hacking, covering-tracks activities should primarily be used to assess:

A. Logging
B. Monitoring
C. Detection capability
D. Incident investigation capability

28. Which are important security logs?

A. Authentication events
B. Account changes
C. Administrative actions
D. Suspicious access attempts

29. Why should ethical hackers avoid deleting real security logs?

A. Logs may be needed for investigation
B. Evidence must be preserved
C. Destruction of evidence can cause operational problems
D. It is unnecessary for a controlled assessment

30. What can centralized logging provide?

A. Consolidated security information
B. Easier investigation
C. Improved monitoring
D. Guaranteed prevention of all attacks

31. Which are examples of security monitoring?

A. Detecting unusual login activity
B. Detecting repeated failed authentication attempts
C. Monitoring privileged actions
D. Ignoring suspicious events

32. Which phase follows reconnaissance in the sequence presented?

A. Scanning
B. Covering Tracks
C. Gaining Access
D. Maintaining Access

33. Which phase normally follows scanning?

A. Gaining Access
B. Reconnaissance
C. Covering Tracks
D. Reporting

34. Which phase follows gaining access?

A. Maintaining Access
B. Reconnaissance
C. Scanning
D. Information gathering

35. Which phase follows maintaining access?

A. Covering Tracks
B. Reconnaissance
C. Scanning
D. Enumeration

36. Which sequence correctly represents the five phases?

A. Reconnaissance → Scanning → Gaining Access → Maintaining Access → Covering Tracks
B. Scanning → Reconnaissance → Covering Tracks → Gaining Access → Maintaining Access
C. Reconnaissance → Gaining Access → Scanning → Covering Tracks → Maintaining Access
D. Scanning → Maintaining Access → Reconnaissance → Gaining Access → Covering Tracks

37. Which activities should occur before active exploitation?

A. Authorization confirmation
B. Scope definition
C. Reconnaissance
D. Appropriate scanning

38. Why is defining scope important?

A. It identifies systems that may be tested
B. It reduces legal and operational risk
C. It prevents unauthorized testing
D. It gives permission to attack every system on the Internet

39. Which are characteristics of ethical hacking?

A. Authorization
B. Defined scope
C. Controlled testing
D. Documentation

40. Which actions are inappropriate during an authorized security assessment?

A. Testing unrelated systems
B. Destroying production data
C. Disclosing confidential information unnecessarily
D. Ignoring the agreed testing scope

41. What should an ethical hacker do after discovering a serious vulnerability?

A. Document it
B. Preserve appropriate evidence
C. Inform the authorized organization
D. Publicly exploit it

42. Which are useful elements of an ethical hacking report?

A. Vulnerability description
B. Evidence
C. Risk level
D. Recommended remediation

43. What can help reduce the impact of ethical hacking tests?

A. Test environments
B. Synthetic data
C. Test accounts
D. Clearly defined scope

44. Which are examples of defensive controls relevant to ethical hacking?

A. Multi-factor authentication
B. Access control
C. Logging
D. Security monitoring

45. Which vulnerabilities may be identified during web application testing?

A. Authentication weaknesses
B. Authorization weaknesses
C. Session-management weaknesses
D. Configuration weaknesses

46. Why are logs important during penetration testing?

A. They provide evidence
B. They support incident investigation
C. They help evaluate detection capabilities
D. They automatically eliminate vulnerabilities

47. Which factors should be considered when evaluating a vulnerability?

A. Potential impact
B. Likelihood of exploitation
C. Affected assets
D. Business consequences

48. Which statements about ethical hacking are correct?

A. It requires authorization
B. It should follow a defined scope
C. It aims to improve security
D. It should minimize unnecessary damage

49. Which activities help an organization detect an attacker?

A. Security logging
B. Network monitoring
C. Authentication monitoring
D. Alert generation

50. What is the overall purpose of the five-phase ethical hacking process?

A. Identify security weaknesses
B. Validate security controls
C. Assess potential attack impact
D. Recommend security improvements